NEXORA ACTIVE DIRECTORY LAB

Penetration Testing & Security Configuration Review

Controlled lab assessment report | 19 October 2026

Environment	Isolated VMware Workstation lab
Domain	nexora.local
Domain Controller	NEXORA-DC — 192.168.23.129
Windows client	DESKTOP-M8PCMPL — 192.168.23.130 (recorded earlier)
Kali tester	192.168.23.131 (recorded earlier)
Scope	AD discovery, SMB/SYSVOL review, password policy and SMB hardening

Scope note: Findings below reflect checks described in the lab notes; this is not a claim that a full enterprise penetration test was completed.

1. Executive Summary

The Kali tester could reach the domain controller over LDAP (TCP/389) and SMB (TCP/445). Authenticated domain-user access allowed listing standard SMB shares and reading selected SYSVOL Group Policy files. Anonymous SMB session setup was accepted, but anonymous IPC$ directory listing and anonymous SYSVOL tree connection were denied. No anonymous SYSVOL data disclosure was demonstrated.

Overall, the strongest hardening item identified is the absence of an account-lockout threshold in the effective password-policy query. Positive controls observed: SMBv1 disabled and SMB signing required/enabled.

2. Environment & Method

Domain: nexora.local. DC: NEXORA-DC / 192.168.23.129. Client: DESKTOP-M8PCMPL / 192.168.23.130 (previously recorded). Tester: Kali Linux / 192.168.23.131 (previously recorded). Test account: NEXORA\labuser1; password intentionally omitted. Activities included LDAP/SMB reachability, authenticated share enumeration, SYSVOL policy-template review, password-policy query, SMB hardening checks, and anonymous access checks.

3. Findings

F-01 — No account-lockout threshold reported

Rating: Medium / Hardening

Evidence/impact: The effective domain password-policy query reported threshold: None. The Default Domain Policy template showed minimum password length 7, complexity enabled, history 24, maximum age 42 days, and LockoutBadCount=0.

Recommendation: Configure a suitable lockout threshold, duration and reset interval. Consider increasing minimum length to at least 12–14 characters where feasible and validate effective policy after changes.

F-02 — Anonymous SMB session setup accepted; data access denied

Rating: Informational

Evidence/impact: SMB probe reported Null Auth: True and smbclient showed Anonymous login successful. Anonymous IPC$ listing returned NT_STATUS_ACCESS_DENIED and anonymous SYSVOL connection returned NT_STATUS_ACCESS_DENIED.

Recommendation: Confirm anonymous access is unnecessary and maintain restrictions. Session setup alone does not prove data exposure; do not classify as a confirmed disclosure.

F-03 — SMB signing required; SMBv1 disabled

Rating: Positive control

Evidence/impact: Server configuration: EnableSMB1Protocol=False, EnableSMB2Protocol=True, RequireSecuritySignature=True, EnableSecuritySignature=True. SMB probe reported signing: True.

Recommendation: Keep SMBv1 disabled and SMB signing required; recheck after configuration changes.

F-04 — Authenticated user can read standard SYSVOL/NETLOGON

Rating: Expected / Review

Evidence/impact: labuser1 listed SYSVOL and NETLOGON; standard policy folders were present. NETLOGON and SYSVOL scripts directories were reported empty.

Recommendation: This is normal for domain users. Review policy and scripts for embedded secrets and unsafe permissions; no secret exposure was established.

F-05 — DC policy template specifies LDAP signing

Rating: Positive indication; runtime not verified

Evidence/impact: Default Domain Controllers Policy GptTmpl.inf contained LDAPServerIntegrity=4,1. Effective runtime state was not independently confirmed.

Recommendation: Verify effective LDAP signing policy and client compatibility with Windows policy/resultant-set checks and approved diagnostics.

4. Evidence Summary

ID	Check	Recorded result
E-01	SMB shares	ADMIN$, C$, IPC$, NETLOGON, SYSVOL listed with authenticated account.
E-02	SYSVOL policies	Default Domain Policy and Default Domain Controllers Policy folders found.
E-03	Password policy	Minimum length 7; history 24; max age about 42 days; complexity enabled; lockout threshold None.
E-04	Anonymous access	Session setup accepted; IPC$ listing and SYSVOL connection denied.
E-05	SMB hardening	SMBv1 disabled; SMB2 enabled; signing required and enabled.
E-06	Network	LDAP 389 and SMB 445 reported open.

5. Remediation Priority

1. Set an appropriate account-lockout threshold, duration and reset interval.
2. Improve password length baseline and encourage passphrases/MFA where possible.
3. Verify effective LDAP signing and other domain-controller policies rather than relying only on the template file.
4. Retain SMBv1 disabled and SMB signing required.
5. Periodically review SYSVOL/GPO/scripts for secrets and permission issues.

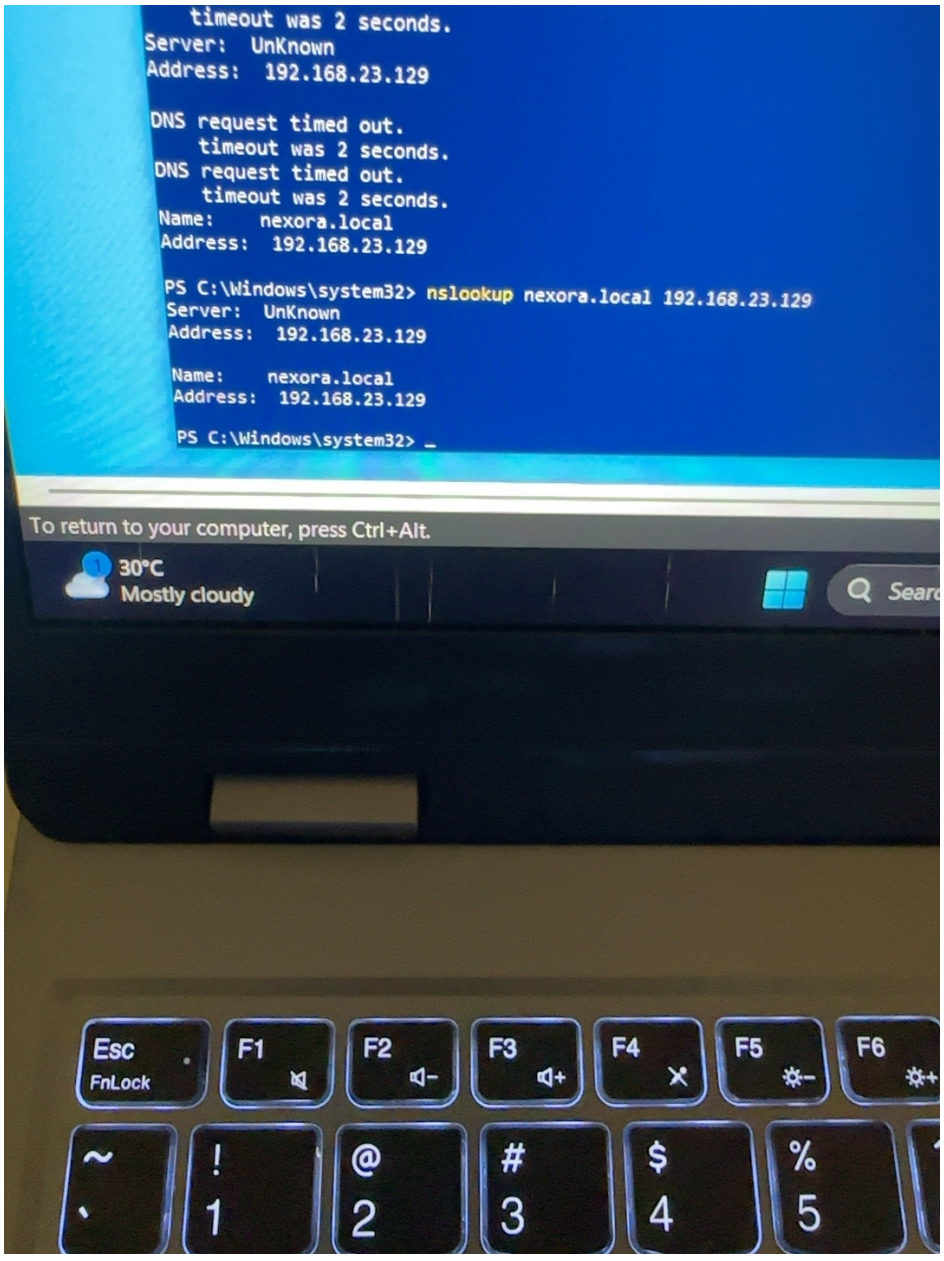
6. Limitations

This report covers an isolated training lab only. No exploitation, password spraying, privilege escalation or data exfiltration is claimed. Effective LDAP signing was not independently verified. Screenshots are included as visual supporting captures from the recent available lab-related images; match them to exact command evidence before formal submission.

Appendix A — Screenshots

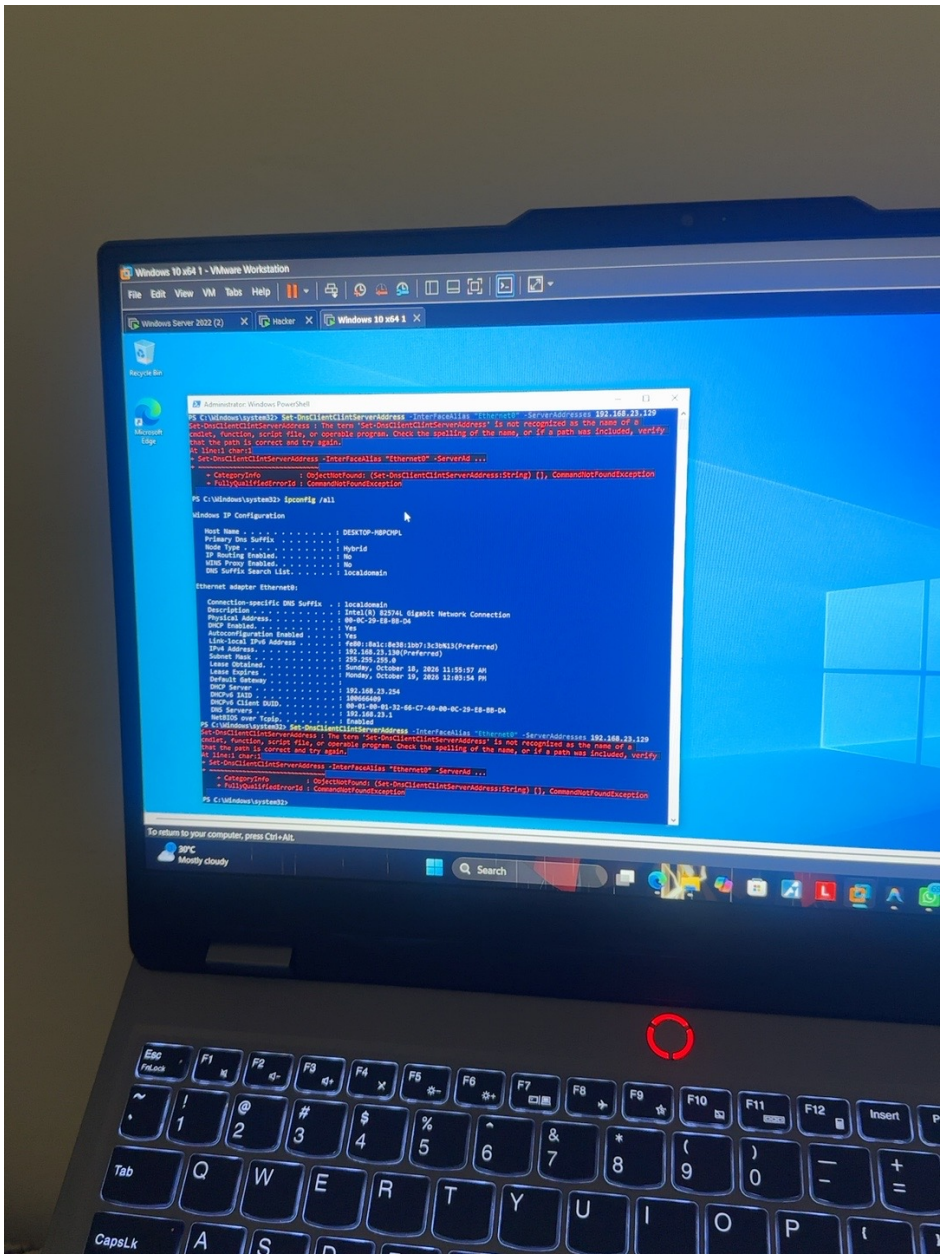
Supporting screen captures. Text evidence summary remains the primary record where camera-photo text is difficult to read.

Screenshot A-1



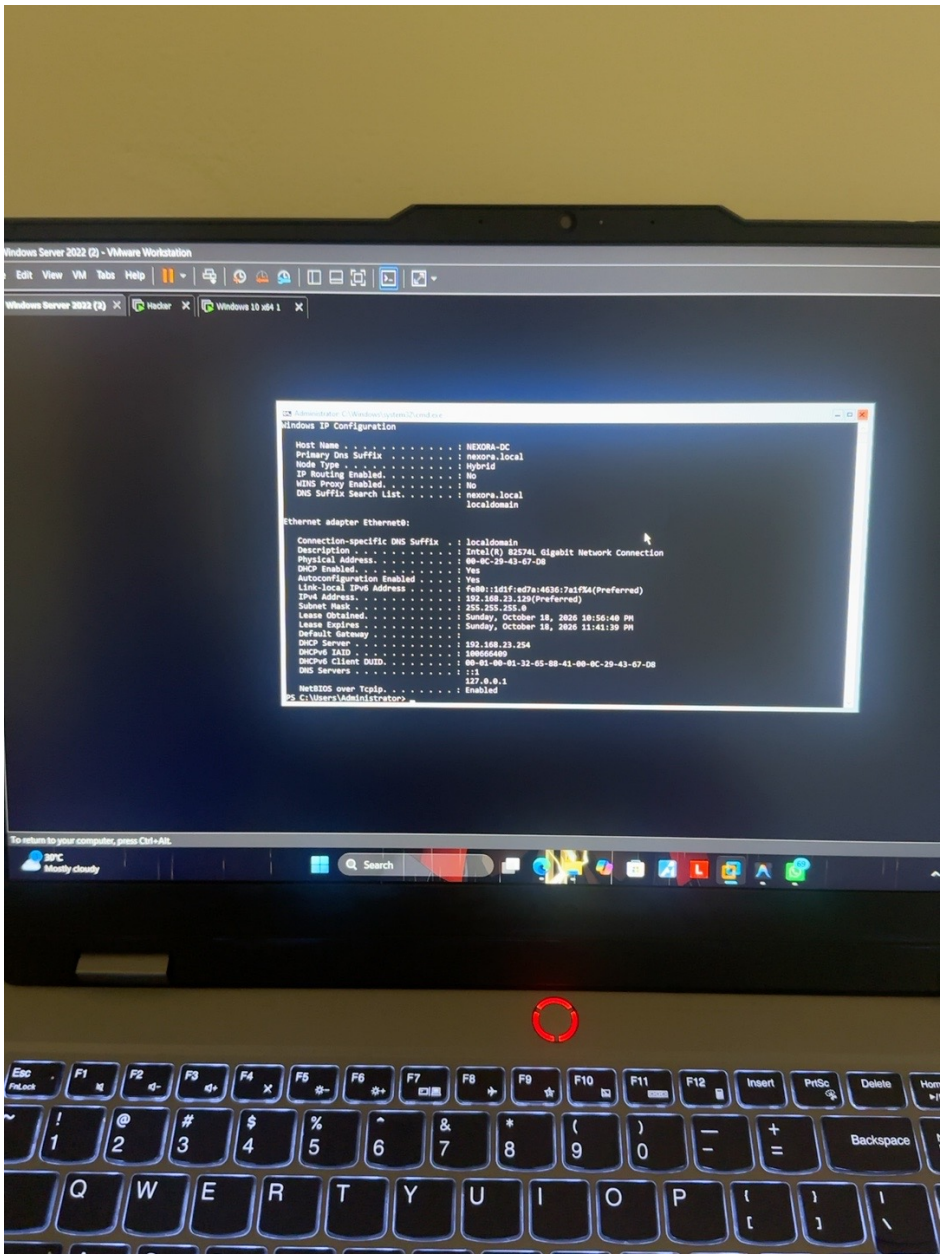
IMG_3CCA7AD7-5762-4F16-8707-54586DF837A1.jpeg

Screenshot A-2



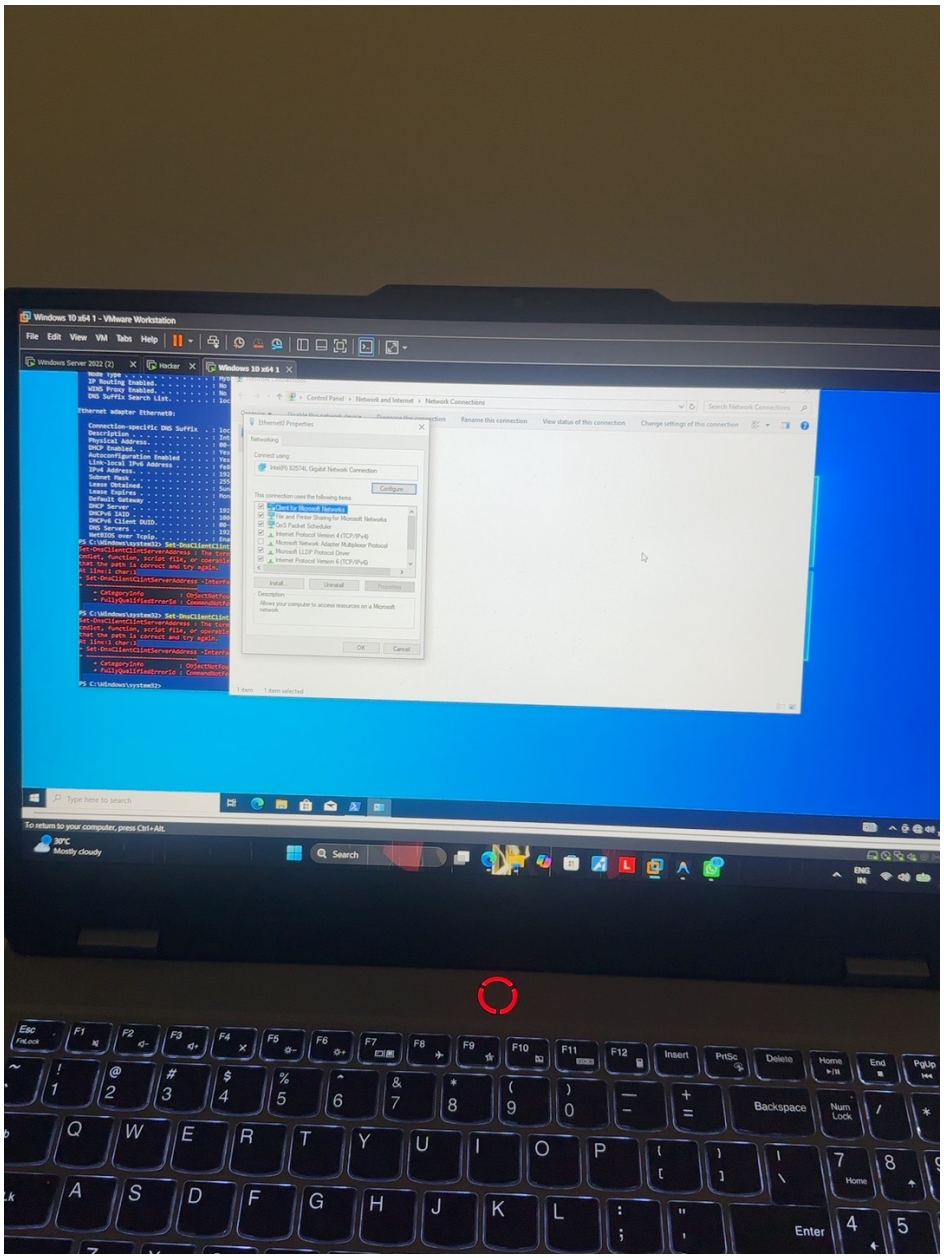
IMG_D72F33A9-311C-4F3A-A078-D93D2B949758.jpeg

Screenshot A-3



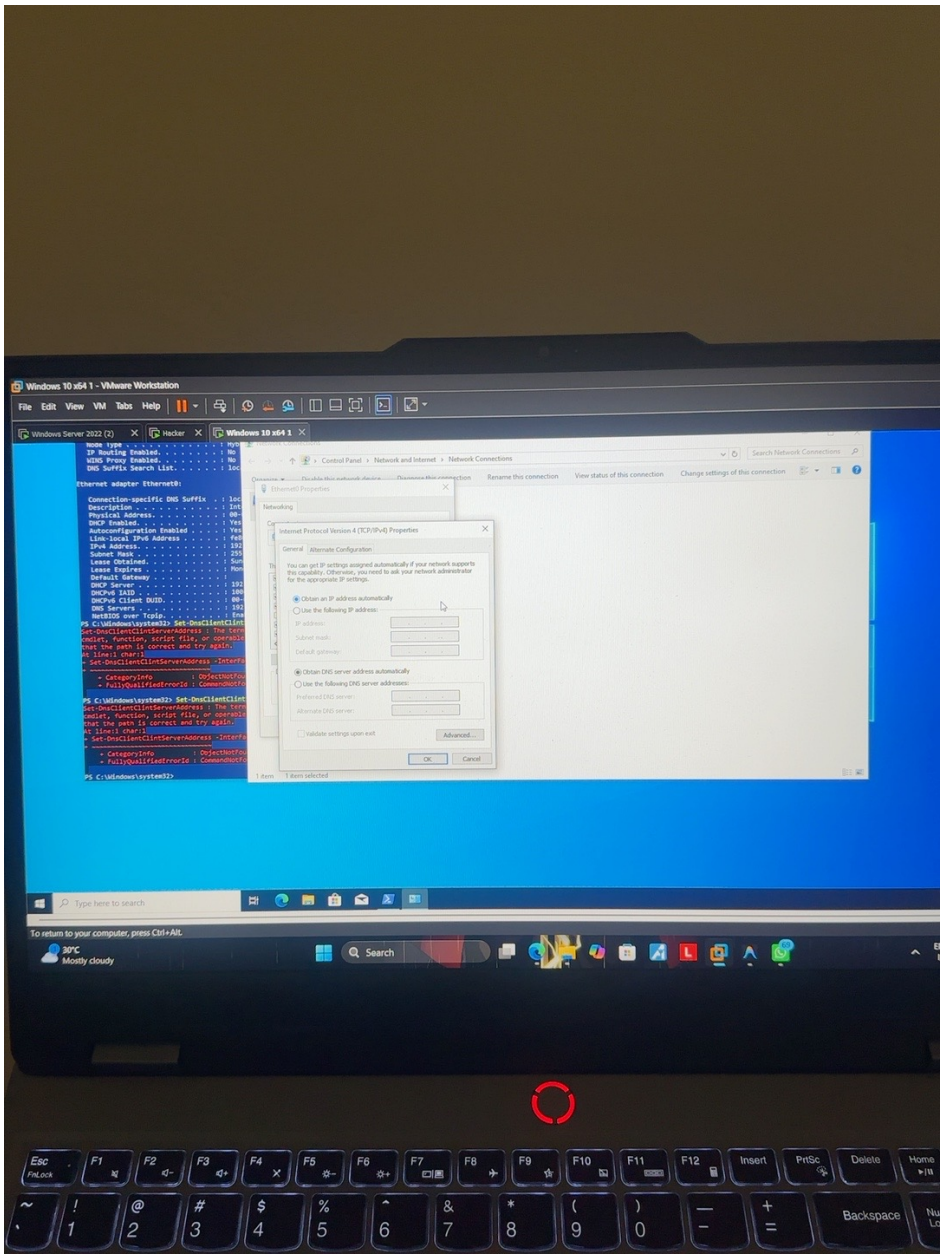
IMG_C1D5805B-26F2-4E3A-BE89-EA2D6B36361A.jpeg

Screenshot A-4



IMG_E3B92702-DC46-439F-958D-E26AF666F5C4.jpeg

Screenshot A-5



IMG_0E4A481A-D9DC-4F60-A83E-4BA40A2DB6EA.jpeg